

UNIVERSIDAD NACIONAL DE LA AMAZONIA PERUANA



UNAP

FISI



TÍTULO:

“ANÁLISIS DE RIESGOS: PLATAFORMA WEB DE COMERCIALIZACIÓN INTEGRAL
DE PRODUCTOS DESARROLLADOS POR ‘INVÉNTALO’”

ASIGNATURA:

ARQUITECTURA DE SISTEMAS DE INFORMACION

Integrantes:

Alvarado Silvano Danilo
Pezo Murrieta Orison
Rengifo Pinedo Brittany
Romero Rosario Niquelson
Torres Flores Julio
Zumaeta Zegarra Walter

Docente:

Ing. Antonio Noronha Gómez

IQUITOS – PERÚ

2026

Contenido

ANÁLISIS DE RIESGOS SEGÚN ISO/IEC 27001.....	3
1. Establecer el Contexto	3
2. Identificación de Activos	4
3. Amenazas y Vulnerabilidades.....	6
4. Metodología para la Valoración de Riesgos	9
5. Valoración de Riesgos.....	10
6. Plan de Tratamiento de Riesgos	13
7. Monitoreo y Revisión	14

ANÁLISIS DE RIESGOS SEGÚN ISO/IEC 27001

1. Establecer el Contexto

Organización: Centro de Investigación, Innovación y Capacitación “Invéntalo”.

Alcance: Análisis centrado en la seguridad de los sistemas de información que gestionan la plataforma web “INVÉNTALO”, destinada a la comercialización integral de productos y servicios. Se incluyen los módulos de gestión de usuarios y roles, clientes, catálogo de productos y cursos, carrito de compras, pedidos, pagos, ticketing del micro museo, generación de reportes y consulta del historial de operaciones por parte de los usuarios.

Contexto Organizacional: El proyecto “INVÉNTALO” consiste en la implementación de una plataforma web orientada a centralizar y automatizar la venta de productos tecnológicos, la inscripción a cursos y la emisión de entradas para el micro museo interactivo. El sistema busca optimizar la gestión administrativa, reducir errores asociados a procesos manuales y mejorar la trazabilidad de las operaciones. Asimismo, permite a los clientes registrarse, realizar compras o inscripciones y consultar su historial de transacciones de manera sencilla a través de una plataforma web accesible.

Contexto Normativo: El sistema debe garantizar la confidencialidad, integridad y disponibilidad de la información, así como la protección de los datos personales de los usuarios. Además, debe asegurar la trazabilidad y transparencia de las transacciones y reportes generados, en concordancia con los principios de la norma ISO/IEC 27001, aunque no contemple integración directa con sistemas contables o fiscales.

Contexto Técnico: El sistema está implementado bajo una arquitectura web tipo SPA con API REST. El backend utiliza Node.js con Express.js y una base de datos MySQL gestionada mediante Sequelize ORM. La autenticación se realiza mediante Google Console (OAuth) y JSON Web Tokens (JWT). El almacenamiento de archivos se gestiona con MinIO y el procesamiento de pagos se integra con la pasarela MercadoPago. El frontend está desarrollado con React v18, Vite, TailwindCSS, React Router DOM, Axios y tecnologías de visualización 3D.

Criterios de Riesgo: Se consideran riesgos **Críticos** aquellos que podrían ocasionar la interrupción total del servicio, fraudes en pagos, acceso no autorizado a información sensible, pérdidas financieras significativas o daño severo a la reputación de la organización. Los riesgos **Altos** implican interrupciones importantes del sistema o vulneraciones de seguridad con impacto considerable. Los riesgos **Medios** pueden generar fallas temporales, reprocesamientos o inconsistencias limitadas en la información. Los riesgos **Bajos** tienen un impacto mínimo en las operaciones. La evaluación de riesgos se basa en una metodología cualitativa que considera el impacto y la probabilidad de ocurrencia.

2. Identificación de Activos

Para la **Plataforma Web de Comercialización Integral de “INVÉNTALO”**, los siguientes **23 activos** son cruciales:

Activos de Información

1. **Base de Datos de Usuarios, Ventas y Operaciones (MySQL):** Contiene datos sensibles de usuarios/clientes, productos/cursos, pedidos, pagos, tickets, inscripciones e historial/auditoría.
2. **Servidor de Aplicaciones (Infraestructura Cloud):** Entorno de ejecución que aloja el backend (Node.js/Express) y expone la API REST que procesa la lógica de negocio.
3. **Repositorio de Objetos (MinIO):** Almacena archivos e imágenes (productos, recursos de cursos y/o adjuntos operativos), asegurando disponibilidad y control de acceso.
4. **Interfaz de Usuario: Panel de Administración:** Permite a los administradores gestionar usuarios/roles, catálogo, stock, pedidos, pagos, cursos, tickets y reportes.
5. **Interfaz de Usuario: Catálogo y Compra:** Vista para que los clientes exploren productos, gestionen el carrito y generen pedidos.
6. **Interfaz de Usuario: Cursos e Inscripción:** Módulo para que los clientes visualicen cursos/talleres y registren inscripciones.
7. **Interfaz de Usuario: Ticketing del Micro Museo:** Módulo para compra/consulta de entradas y control del estado del ticket (vigente/usado/anulado).
8. **Credenciales de Acceso y Tokens (OAuth/JWT):** Nombres de usuario y contraseñas (hasheadas), tokens JWT y credenciales OAuth de Google (activos críticos de seguridad).

Activos Físicos

9. **Infraestructura de Servidores en la Nube:** Servidores físicos del proveedor cloud que alojan la aplicación, la base de datos y MinIO, asegurando operación continua.
10. **Estaciones de Trabajo de Desarrollo (Laptops/PC):** Equipos del equipo utilizados para codificar, probar, administrar y desplegar la plataforma; contienen código y credenciales.
11. **Equipos de Operación (Administración/Soporte):** Dispositivos usados por el rol administrador para gestionar pedidos, pagos, stock y reportes.

12. **Equipos de Red Local (Routers/Switches):** Dispositivos que proporcionan conectividad a internet para administrar los servicios en la nube y acceder al panel.

Activos de Software

13. **Aplicación Web “INVÉNTALO”:** Sistema principal que gestiona catálogo, carrito, pedidos, pagos (MercadoPago), cursos, tickets, reportes e historial.
14. **Código Fuente del Proyecto:** Conjunto de archivos del frontend y backend que componen la aplicación y representan la propiedad intelectual del proyecto.
15. **Framework/Librerías Frontend (React v18 + Vite + TailwindCSS):** Tecnologías sobre las que se construye la interfaz del cliente (SPA), enrutamiento y experiencia de usuario.
16. **Runtime/Framework Backend (Node.js + Express.js):** Tecnologías sobre las que se construye la API REST y la lógica de negocio del sistema.
17. **ORM Sequelize:** Herramienta para la gestión de modelos, validaciones y operaciones sobre la base de datos MySQL.
18. **SGBD MySQL:** Motor de base de datos relacional utilizado para almacenar de forma persistente y segura la información del sistema.
19. **Integración de Pagos (MercadoPago):** Servicio y componentes de integración (incluyendo confirmación vía backend/webhooks) para procesar pagos y actualizar estados de pedidos.

Activos de Personal

20. **Líder de Proyecto / Desarrollador Principal:** Responsable de la supervisión general, decisiones técnicas, seguridad base, despliegue y mantenimiento del sistema.
21. **Equipo de Desarrollo y Soporte:** Miembros con roles de backend, frontend, base de datos, QA/pruebas, UI/UX y documentación.
22. **Rol “Administrador/Gestor”:** Usuario con permisos elevados para administrar catálogo, stock, pedidos, pagos, cursos, tickets y reportes.
23. **Usuarios Finales (Clientes):** Usuarios externos que realizan compras, se inscriben a cursos, adquieren tickets y consultan su historial (principal fuente de datos personales y transacciones).

3. Amenazas y Vulnerabilidades

Se han identificado las siguientes amenazas y vulnerabilidades:

Nombre Activo	Amenaza	Vulnerabilidad
Base de Datos de Usuarios, Ventas y Operaciones (MySQL)	Filtración de Datos (Data Breach)	Fallos en control de acceso, credenciales/secretos expuestos, permisos excesivos o copias de BD sin protección.
Servidor de Aplicaciones (Infraestructura Cloud)	Paralización del Servicio por Agotamiento de Recursos	Falta de monitoreo, límites y escalamiento; picos de tráfico o procesos pesados sin control.
Repositorio de Objetos (MinIO)	Exposición pública de archivos	Buckets/políticas mal configuradas, URLs sin expiración, ausencia de control de acceso por roles.
Interfaz de Usuario: Panel de Administración	Cross-Site Scripting (XSS)	Renderización de datos sin sanitización/escape en listados, formularios o reportes del panel.
Interfaz de Usuario: Catálogo y Compra	Manipulación de precios / fraude de compra	Validaciones solo en frontend (precio, descuentos, stock) sin verificación estricta en backend.
Interfaz de Usuario: Cursos e Inscripción	Acceso no autorizado a contenido/inscripciones	Falta de control por estado de pago/inscripción y autorización por roles.

Interfaz de Usuario: Ticketing del Micro Museo	Reutilización/Falsificación de tickets	Tokens de ticket predecibles, sin expiración, sin estado “usado/anulado” validado en servidor.
Credenciales de Acceso y Tokens (OAuth/JWT)	Ataque de Fuerza Bruta / Toma de cuenta	Sin rate limiting, sin bloqueo por intentos, secretos JWT débiles o expiración excesiva.
Infraestructura de Servidores en la Nube	Caída del proveedor / indisponibilidad regional	Dependencia de una sola región o falta de plan de respaldo/recuperación.
Estaciones de Trabajo de Desarrollo (Laptops/PC)	Infección por Malware / robo de credenciales	Antivirus desactualizado, llaves/API en texto plano, descarga de herramientas no confiables.
Equipos de Operación Administrativa	Robo/Pérdida del dispositivo	Falta de cifrado, bloqueo de pantalla o sesiones persistentes sin cierre/expiración.
Equipos de Red Local (Routers/Switches)	Interrupción de conectividad / MITM	Equipos sin mantenimiento, firmware viejo, Wi-Fi inseguro o contraseñas por defecto.
Aplicación Web “e-commerce INVÉNTALO”	Inyección SQL / acceso indebido	Validación insegura de entradas o endpoints sin autorización uniforme (fallas de RBAC).
Código Fuente del Proyecto	Fuga de Propiedad Intelectual	Repositorio público por error, acceso sin MFA o secretos expuestos en el repositorio.

Frameworks/Librerías Frontend (React, Vite, TailwindCSS)	Dependencias vulnerables (Supply Chain)	Librerías sin actualización ni escaneo, paquetes comprometidos o versiones obsoletas.
Runtime y Framework Backend (Node.js y Express.js)	Exposición de endpoints críticos	CORS mal configurado, falta de middleware de autorización, rutas admin accesibles indebidamente.
ORM Sequelize	Corrupción de datos / bypass de validaciones	Uso de consultas “raw” inseguras, validaciones incompletas o falta de transacciones en operaciones críticas.
SGBD MySQL	Rendimiento degradado	Falta de índices, consultas no optimizadas, crecimiento de tablas sin mantenimiento/monitoreo.
Pasarela de Pagos (MercadoPago)	Confirmación falsa de pago / fraude	No validar pagos con webhook y verificación server-side; confiar en respuesta del cliente sin conciliación.
Líder de Proyecto / Desarrollador Principal	Fuga de conocimiento clave	Alta dependencia de una sola persona para despliegue, claves y arquitectura (bus factor).
Equipo de Desarrollo y Soporte	Falta de comunicación / errores en cambios	Ausencia de code review, pruebas, control de cambios y estándares de despliegue.
Rol “Administrador/Gestor”	Abuso de privilegios / error humano	Permisos excesivos, falta de auditoría de acciones, ausencia de doble

		validación en acciones críticas.
Usuarios Finales (Clientes)	Phishing / robo de cuenta	Contraseñas reutilizadas y falta de alertas, medidas anti-bot o segundo factor opcional.

4. Metodología para la Valoración de Riesgos

a. Determinación del Impacto

El impacto representa la magnitud de las consecuencias que se producirían si una amenaza llegara a materializarse sobre los activos del e-commerce. Se evalúa en función de la afectación a la **confidencialidad, integridad y disponibilidad** de la información, así como del impacto operativo, financiero y reputacional.

Escala cualitativa de Impacto

Nivel	Descripción	Ejemplo
Alto	Afecta operaciones críticas en la página web, genera pérdidas financieras significativas, expone datos sensibles o daña gravemente la reputación.	Caída total de la página web que impide realizar ventas y pagos, fraude en transacciones mediante MercadoPago o filtración masiva de datos personales de clientes.
Medio	Interrupción temporal de servicios importantes o pérdida parcial de información.	Indisponibilidad temporal del sistema de compras o errores en el registro de pedidos que requieren reprocesamiento manual.
Bajo	Daño leve que afecta funciones no críticas sin comprometer la operación principal.	Error visual en el catálogo de productos o retraso menor en la generación de reportes administrativos.

b. Determinación de la Probabilidad

La probabilidad mide la posibilidad de que una amenaza ocurra, considerando factores como el entorno tecnológico de la página web, la exposición a internet, los controles de seguridad implementados y antecedentes de incidentes similares.

Escala cualitativa de Probabilidad

Nivel	Descripción
Alta	Es probable que ocurra con frecuencia debido a la exposición constante de la página web a internet o controles insuficientes.
Media	Puede ocurrir bajo determinadas circunstancias o fallos específicos de control.
Baja	Tiene pocas probabilidades de ocurrir debido a controles efectivos o baja exposición.

c. Matriz de Riesgo (Impacto × Probabilidad):

		IMPACTO		
PROBABILIDAD		Bajo	Medio	Alto
	Alta	Medio	Alto	Crítico
	Media	Bajo	Medio	Alto
	Baja	Bajo	Bajo	Medio

5. Valoración de Riesgos

ACTIVO	DESCRIPCIÓN DEL RIESGO	VULNERABILIDAD	PROBABILIDAD	IMPACTO	NIVEL DE RIESGO
Base de Datos de Usuarios, Ventas y Operaciones (MySQL)	Riesgo de extracción, alteración o eliminación de datos	Controles de acceso insuficientes, credenciales	Media	Alto	Alto

	sensibles de clientes, pedidos y pagos por acceso no autorizado.	expuestas o falta de cifrado.			
Servidor de Aplicaciones (Infraestructura Cloud)	Riesgo de indisponibilidad total del e-commerce por fallos o saturación de recursos.	Falta de monitoreo y escalamiento automático.	Media	Alto	Alto
Repositorio de Objetos (MinIO)	Riesgo de exposición pública de imágenes y archivos del e-commerce.	Políticas de acceso mal configuradas o URLs sin expiración.	Media	Medio	Medio
Interfaz de Usuario: Panel de Administración	Riesgo de secuestro de sesión o manipulación de acciones administrativas (XSS).	Falta de sanitización de entradas y salidas.	Media	Medio	Medio
Interfaz de Usuario: Catálogo y Compra	Riesgo de manipulación de precios, descuentos o stock durante el proceso de compra.	Validaciones solo en frontend.	Media	Alto	Alto
Interfaz de Usuario: Cursos e Inscripción	Riesgo de acceso a cursos sin pago o inscripción válida.	Falta de validación por estado de pago.	Baja	Medio	Bajo
Interfaz de Usuario: Ticketing del Micro Museo	Riesgo de reutilización o falsificación de tickets.	Tokens predecibles o sin control de estado.	Media	Alto	Alto
Credenciales de Acceso y Tokens (OAuth/JWT)	Riesgo de toma de cuentas por fuerza bruta o robo de tokens.	Ausencia de rate limiting y expiración larga de tokens.	Alta	Alto	Crítico
Infraestructura de Servidores en la Nube	Riesgo de interrupción prolongada del servicio por fallos del proveedor.	Dependencia de una sola región.	Baja	Alto	Medio
Estaciones de Trabajo de Desarrollo (Laptops/PC)	Riesgo de fuga de código fuente y credenciales por robo o pérdida.	Falta de cifrado de disco y controles de seguridad.	Media	Alto	Alto

Equipos de Operación Administrativa	Riesgo de acceso indebido por pérdida o robo del dispositivo.	Sesiones persistentes y falta de bloqueo.	Media	Medio	Medio
Equipos de Red Local (Routers/Switches)	Riesgo de imposibilidad de administración del e-commerce por fallas de red.	Infraestructura sin redundancia.	Media	Bajo	Bajo
Aplicación Web “e-commerce INVÉNTALO”	Riesgo de inyección SQL o acceso indebido a datos.	Validación insuficiente y errores en autorización.	Baja	Alto	Medio
Código Fuente del Proyecto	Riesgo de exposición pública del código y secretos.	Repositorio mal configurado.	Baja	Alto	Medio
Frameworks/Librerías Frontend	Riesgo por dependencias vulnerables (supply chain).	Falta de actualización y escaneo de dependencias.	Media	Medio	Medio
Runtime y Framework Backend (Node.js/Express)	Riesgo de explotación de endpoints críticos.	CORS y middleware de seguridad mal configurados.	Media	Alto	Alto
ORM Sequelize	Riesgo de corrupción o inconsistencia de datos.	Uso inseguro de consultas raw y falta de transacciones.	Media	Medio	Medio
SGBD MySQL	Riesgo de degradación del rendimiento.	Consultas no optimizadas e índices inexistentes.	Alta	Medio	Alto
Pasarela de Pagos (MercadoPago)	Riesgo de confirmación falsa de pagos o fraude.	No validación de pagos vía webhooks.	Media	Alto	Alto
Líder de Proyecto / Desarrollador Principal	Riesgo de dependencia excesiva del conocimiento técnico.	Ausencia de documentación formal.	Media	Alto	Alto
Equipo de Desarrollo y Soporte	Riesgo de errores en producción por mala coordinación.	Falta de procesos formales y revisiones.	Media	Medio	Medio

Rol "Administrador/Gestor"	Riesgo de abuso de privilegios o errores críticos.	Permisos excesivos y falta de auditoría.	Media	Alto	Alto
Usuarios Finales (Clientes)	Riesgo de phishing y robo de cuentas.	Contraseñas débiles y ausencia de alertas.	Alta	Medio	Alto

6. Plan de Tratamiento de Riesgos

Para cada riesgo identificado, se proponen las siguientes estrategias de mitigación, con un enfoque en la implementación técnica:

ACTIVO	DESCRIPCIÓN DE CONTROL	EVIDENCIA	PROB. RESIDUAL	IMPACTO RESIDUAL	NIVEL RESIDUAL
Base de Datos MySQL	Implementar cifrado, roles con mínimo privilegio y auditoría de accesos.	Configuración de BD y logs.	Baja	Alto	Medio
Servidor de Aplicaciones	Configurar monitoreo, alertas y escalamiento automático.	Panel de monitoreo cloud.	Baja	Medio	Bajo
MinIO	Restringir acceso por políticas y usar URLs temporales.	Configuración de buckets.	Baja	Medio	Bajo
Credenciales y Tokens	Aplicar rate limiting, expiración corta	Código de autenticación.	Baja	Alto	Medio

	y rotación de JWT.				
MercadoPago	Validar pagos solo vía webhooks firmados.	Logs de webhooks.	Baja	Alto	Medio
Código Fuente	Repositorio privado con ramas protegidas y MFA.	Configuración Git.	Baja	Alto	Medio
Líder de Proyecto	Documentación técnica y transferencia de conocimiento.	Manual técnico y actas.	Baja	Medio	Bajo

7. Monitoreo y Revisión

El monitoreo continuo es esencial para detectar desviaciones, evaluar la efectividad de los controles de seguridad implementados y asegurar la disponibilidad, rendimiento e integridad del e-commerce “INVÉNTALO”.

- **Disponibilidad del Servicio (RNF-Disponibilidad):**
 - Métrica: Tiempo de actividad (*uptime*) del e-commerce y de la API REST.
 - Objetivo: > 99.9% de uptime mensual.
 - Herramienta: UptimeRobot y monitoreo nativo del proveedor cloud.
- **Rendimiento de la Plataforma (RNF-Rendimiento):**
 - Métrica: Tiempo promedio de carga de las vistas más utilizadas (Login, Catálogo, Carrito, Checkout, Panel de Administración).
 - Objetivo: < 2 segundos por vista en condiciones normales.
 - Herramienta: Google Lighthouse (auditorías periódicas), herramientas de monitoreo de frontend (ej. Sentry) y métricas del servidor Node.js.
- **Integridad de Datos y Operaciones (RNF-Integridad):**

- Métrica: Porcentaje de pedidos, pagos e inscripciones procesados correctamente sin reprocesos.
- Objetivo: > 98% de operaciones exitosas.
- Herramienta: Logs del backend (Node.js/Express), registros de transacciones y validaciones en base de datos MySQL.
- **Seguridad de Autenticación y Acceso (RNF-Seguridad):**
 - Métrica: Número de intentos fallidos de inicio de sesión por usuario en un período de 24 horas.
 - Objetivo: < 5 intentos fallidos por usuario.
 - Métrica adicional: Detección de accesos inusuales (múltiples IPs, ubicaciones o dispositivos en corto tiempo).
 - Herramienta: Logs de autenticación (JWT/OAuth), análisis de logs del backend y alertas de seguridad.
- **Uso de Recursos del Sistema (RNF-Capacidad):**
 - Métrica: Uso de CPU y RAM del servidor de aplicaciones.
 - Objetivo: Mantener el uso promedio por debajo del 70%.
 - Herramienta: Dashboards del proveedor cloud y monitoreo del runtime Node.js.
 - Métrica adicional: Crecimiento del almacenamiento de base de datos MySQL y del repositorio de objetos MinIO.
 - Objetivo: Monitorear crecimiento y proyectar capacidad para evitar saturación.
 - Herramienta: Paneles de administración de MySQL y MinIO.
- **Procesamiento de Pagos (RNF-Confiableidad):**
 - Métrica: Porcentaje de pagos confirmados correctamente mediante MercadoPago (webhooks válidos).
 - Objetivo: > 99% de pagos conciliados correctamente.
 - Herramienta: Logs de webhooks de MercadoPago y registros del backend.
- **Cumplimiento de Backups y Recuperación:**
 - Métrica: Porcentaje de respaldos exitosos de la base de datos y archivos críticos.
 - Objetivo: 100% de éxito en backups programados.
 - Herramienta: Registros del sistema de backups del proveedor cloud y pruebas periódicas de restauración.